

Simon Gallego Giraldo

Juan David Benjumea Rondon

Luis Miguel Hernández

Juan Manuel Reina

Institución Universitaria Pascual Bravo

Pruebas de Software

Jeisson Ibarguen Maturana

Medellín - Antioquia

6 de junio de 2025

Matriz de trazabilidad

ID	CATEGORÍA	PRIORIDAD	FUENTE/SOURCE	OBJETIVO	HERRAMIENTA
1	Funcional	Alta	https://pascualbravo.in/gejei.com/registro-y-busqueda/	Verificar que el flujo de registro de usuario funcione correctamente	Selenium
2	Funcional	Alta	https://pascualbravo.in/gejei.com/registro-y-busqueda/	Validar la búsqueda de productos por palabra clave	Selenium
3	Funcional	Alta	https://pascualbravo.in/gejei.com/cart/	Probar añadir y eliminar productos del carrito	Selenium
4	Funcional	Crítica	https://pascualbravo.in/gejei.com/cart/	Comprobar el flujo de pago con tarjeta (WooCommerce)	Selenium
5	Funcional	Alta	https://pascualbravo.in/gejei.com/registro-y-busqueda/	Validar el envío de correos transaccionales (confirmación de pedido, restablecer contraseña)	Selenium
6	Funcional	Crítica	https://pascualbravo.in/gejei.com	Simular 500 usuarios concurrentes en la página de inicio	Jmeter

7	Carga	Crítica	pascualbravo.ingejei.com/cart/checkout	Medir el tiempo de respuesta al procesar un checkout con 100 usuarios simultáneos	Jmeter
8	Carga	Alta	https://pascualbravo.ingejei.com	Ejecutar un test de estrés subiendo archivos grandes en paralelo	Jmeter
9	Carga	Alta	https://pascualbravo.ingejei.com	Analizar el rendimiento de la base de datos con 200 consultas/segundo	Jmeter
10	Carga	Alta	https://pascualbravo.ingejei.com	Realizar un test de resistencia continuo durante 2 horas con 100 usuarios	Jmeter
11	Seguridad	Crítica	https://pascualbravo.ingejei.com/my-account	Ejecutar escaneos de vulnerabilidades (SQL Injection) en todos los formularios	Kali Linux
12	Seguridad	Crítica	https://pascualbravo.ingejei.com/my-account	Probar fuerza bruta de inicio de sesión con diccionario	Kali Linux

13	Seguridad	Alta	https://pascualbravo.in/gejei.com/wp-login.php https://pascualbravo.in/gejei.com/wp-admin/	Auditar la gestión de permisos intentando accesos no autorizados	Kali Linux
14	Seguridad	Alta	https://pascualbravo.in/gejei.com	Revisar encabezados HTTP de seguridad (CSP, HSTS, X-Frame-Options)	Kali Linux
15	Seguridad	Crítica	https://pascualbravo.in/gejei.com	Probar protección contra CSRF con y sin token válido	Kali Linux

Checklist OWASP Top 10

ITEM	CATEGORÍA	CHECKLIST (Qué se verifica?)	¿Cómo se verifica?
A1	Inyección	¿Se puede acceder a los datos con seguridad? ¿Están bien definidos los roles?	Ingresar desde la ruta de login desde la aplicación y validar que esté activo el https desde el navegador y después de ingresar validar el network (consola de desarrollador) u otra herramienta que permita capturar la transmisión de datos (SELENIUM). Verificar desde la cuenta del administrador de la aplicación si se puede crear usuarios con diferentes roles y autenticarse luego.

			(posteriormente pasar la verificación número 1)
A2	Pérdida de autenticación y gestión de sesiones	¿Las sesiones expiran correctamente? ¿Se puede acceder sin login desde otra pestaña o equipo? ¿Se puede forzar el login sin credenciales?	Iniciar sesión en WordPress y cierra el navegador. Luego, vuelve a abrir y revisa si la sesión sigue activa. Usar Selenium para automatizar el cierre y reapertura de sesión. Verificar si puedes copiar cookies de sesión (con extensiones del navegador o dev tools) y usarlas en otro navegador para simular robo de sesión.
A3	Datos sensibles accesibles	¿Se están transmitiendo datos sensibles (contraseñas, tarjetas) en texto plano? ¿Hay datos personales visibles sin login?	Usar la consola del navegador (Network) y JMeter para interceptar peticiones con credenciales y ver si están encriptadas. Navegar a URLs sensibles sin autenticar y revisa si se muestran datos.
A4	Entidad externa de XML (XXE)	¿Se usan entradas XML que puedan ser manipuladas para acceder a archivos o servicios internos?	Usar JMeter o una herramienta como Burp Suite para probar cargas maliciosas si hay carga de archivos XML.
A5	Control de acceso inseguro	¿Los usuarios pueden acceder a páginas o funciones restringidas? ¿Pueden realizar acciones como modificar productos sin ser administradores?	Acceder como usuario normal y prueba entrar a rutas administrativas directamente. Usar Selenium para automatizar el acceso a menús o acciones que

			deberían estar ocultas (como editar productos o ver reportes de ventas).
A6	Configuración de seguridad incorrecta	¿Están activos plugins innecesarios? ¿Está activo el modo debug en producción? ¿Se muestran errores detallados?	En el archivo <code>wp-config.php</code>, revisa si hay líneas como <code>define('WP_DEBUG', true);</code> (debe estar en false). Visitar URLs erróneas y revisar si se muestran mensajes de error con detalles del sistema. Usar JMeter o navegador para probar endpoints no documentados.
A7	Cross site scripting (XSS)	¿Es posible inyectar scripts (por ejemplo, en formularios, comentarios o campos de productos)?	Ingresa <code><script>alert("XSS")</script></code> en formularios como el de contacto, búsqueda, comentarios o reseñas de productos. Usar Selenium para automatizar la inyección y ver si aparece la alerta al cargar la página.
A8	Decodificación insegura	¿Hay campos que acepten objetos codificados que puedan ser modificados para ejecutar código?	Revisar si hay cookies codificadas en Base64 o JSON y prueba a modificarlas. Usar JMeter para interceptar una cookie o parámetro y alterarlo (por ejemplo, cambiar el rol a <code>admin</code> en una cookie serializada).
A9	Componentes con vulnerabilidades	¿Se usan plugins o temas con vulnerabilidades conocidas?	Usar un escáner como WPScan para analizar el sitio y ver qué plugins y

			versiones tienen vulnerabilidades. También puedes revisar manualmente la lista de plugins desde https://pascualbravo.ingejei.com/wp-admin/plugins.php y buscar sus versiones en sitios como CVE Details.
A10	Insuficiente monitorización y registro	¿Se registran los accesos fallidos, cambios importantes o acciones críticas? ¿Hay alertas ante múltiples accesos erróneos?	Realiza múltiples intentos de login fallidos y observa si el sistema los bloquea o registra. Accede al panel de administración y revisa si hay un log o plugin instalado para auditoría como WP Security Audit Log.

Caso de Prueba

ID	Descripción	Precondición	Entrada	Resultado esperado
PF-01	Verificar que el flujo de registro funcione correctamente.	Página de registro disponible	https://pascualbravo.ingejei.com/registro-y-busqueda/	Usuario registrado, mensaje de éxito, redirección al login
PF-02	Validar la búsqueda de productos por palabra clave.	Productos creados, barra de búsqueda activa	https://pascualbravo.ingejei.com/registro-y-busqueda/	Resultados relevantes con imagen, precio y stock
PF-03	Probar añadir y eliminar productos del carrito.	Usuario autenticado, productos disponibles	https://pascualbravo.ingejei.com/cart/	Carrito actualizado correctamente sin residuos
PF-04	Comprobar el flujo	Método de pago	https://pascualbravo.ingejei.com/	Pedido generado

	de pago con tarjeta.	configurado, carrito con productos	ingejei.com/cart/	correctamente, usuario notificado
PF-05	Validar el envío de correos transaccionales (confirmación de pedido, restablecer contraseña).	SMTP configurado, usuario registrado	https://pascualbravo.ingejei.com/registro-y-busqueda/	Correos enviados: confirmación de pedido, restablecer contraseña
PC-01	Simular 500 usuarios concurrentes en la página de inicio.	JMeter configurado con plan de prueba	https://pascualbravo.ingejei.com	Tiempo de respuesta por debajo de 2s.
PC-02	Medir el tiempo de respuesta al procesar un checkout con 100 usuarios simultáneos	Flujo de pago funcional, productos cargados	https://pascualbravo.ingejei.com/cart/checkout	Tiempo de respuesta aceptable, sin timeout
PC-03	Ejecutar un test de estrés subiendo archivos grandes en paralelo	Funcionalidad de subida activa	https://pascualbravo.ingejei.com	Sistema soporta carga masiva sin errores
PC-04	Analizar el rendimiento de la base de datos con 200 consultas/segundo.	Base de datos poblada, JMeter configurado	https://pascualbravo.ingejei.com	Sin cuellos de botella, consultas procesadas eficientemente
PC-05	Realizar un test de resistencia continuo durante 2 horas con 100 usuarios.	Ambiente estable, prueba prolongada	https://pascualbravo.ingejei.com	Sin fugas de memoria, estabilidad mantenida

PS-01	Ejecutar escaneos de vulnerabilidades (SQL Injection) en todos los formularios.	Formulario vulnerable, sqlmap instalado	https://pascualbravo.ingejei.com/my-account	Aplicación protegida contra SQL o identificado punto vulnerable
PS-02	Probar fuerza bruta de inicio de sesión con diccionario	Lista de usuarios y diccionario disponibles	https://pascualbravo.ingejei.com/my-account	Bloqueo por intentos fallidos o captcha activado
PS-03	Auditar la gestión de permisos intentando accesos no autorizados	Credenciales válidas con distintos roles	https://pascualbravo.ingejei.com/wp-login.php/ https://pascualbravo.ingejei.com/wp-admin/	Acceso denegado a usuarios sin privilegios
PS-04	Revisar encabezados HTTP de seguridad (CSP, HSTS, X-Frame-Options)	Sitio en HTTPS, curl disponible	https://pascualbravo.ingejei.com	Encabezados de seguridad presentes (CSP, HSTS, XFO, XCTO)
PS-05	Probar protección contra CSRF con y sin token válido.	Formularios con token y cookies analizados	https://pascualbravo.ingejei.com	Peticiones sin token son rechazadas; con token válidas

Pruebas Funcionales

Primera prueba realizada por Luis Miguel Hernandez (PF-01)

Project: Prueba Registro dde Usuarios*

Tests +

Search tests...

https://pascualbravo.ingejei.com

	Command	Target	Value
1	open	/registro-y-busqueda/	
2	set window size	1552x832	
3	click	linkText=Acceder	
4	click	linkText=Registrarse	
5	click	id=user_login	
6	type	id=user_login	Luis Hernandez
7	click	id=user_email	
8	type	id=user_email	luis.hernandez147@pascualbravo.edu.co
9	click	id=wp-submit	
10	click	linkText=página de acceso	

Command

Target

Value

Description

LogReference

Prueba exitosa

Segunda prueba realizada por Luis Miguel Hernandez (PF-02)

Project: Busqueda de Productos

Executing

X Busqueda de Productos

https://pascualbravo.ingejei.com

	Command	Target	Value
1	✓ open	/registro-y-busqueda/	
2	✓ set window size	882x816	
3	✓ click	id=wp-block-search__input-2	
4	✓ type	id=wp-block-search__input-2	Beanie
5	✓ click	css= wp-block-search__button	
6	X click	linkText=Read more	

Command

Target

Value

Description

Runs: 1 Failures: 1

LogReference

Prueba fallida

Tercera prueba realizada por Luis Miguel Hernandez (PF-03)

Project: Prueba Añadir y Eliminar Productos del Carrito*

Tests +

Search tests...

https://pascualbravo.ingeji.com

✓ Añadir y Eliminar Product

	Command	Target	Value
1	✓ open	/	
2	✓ set window size	1552x832	
3	✓ click	css= has-color2-color > .has-medium-font-size:nth-child(5) .wp-block-navigation-item__label	
4	✓ click	css= wc-block-product:nth-child(2) .wp-block-button__link	
5	✓ click	css= wc-block-product:nth-child(3) .wp-block-button__link > span	
6	✓ click	css= has-color2-color > .has-medium-font-size:nth-child(6) .wp-block-navigation-item__label	
7	✓ click	css= wc-block-cart-items__row:nth-child(1) .wc-block-components-quantity-selector__button--minus	
8	✓ click	css= wc-block-cart-items__row:nth-child(1) .wc-block-cart-item__remove-link	

Command

Target

Value

Description

Log

Reference

Prueba exitosa

Cuarta prueba realizada por Luis Miguel Hernandez (PF-04)

258963

3216549877

Subtotal

Opciones de pago

Total

No hay ningún método de pago disponible. Esto puede ser error nuestro. Por favor, contáctanos si necesitas ayuda para realizar tu pedido.

☒

Añade una nota a tu pedido

Notas sobre tu pedido.

 No se ha facilitado ningún método de pago.

Información de contacto

Usaremos este correo electrónico para enviarte detalles y actualizaciones relacionadas con tu pedido.

Dirección de correo electrónico

jeisim18@gmail.com

Dirección de facturación

Introduce la dirección que coincida con tu método de pago.

País/Región

Colombia

Nombre

Luis

Apellidos

Hernandez

Resumen del pedido

1

Beanie

\$20.00

\$18.00

This is a simple product.

Añade un cupón

Subtotal

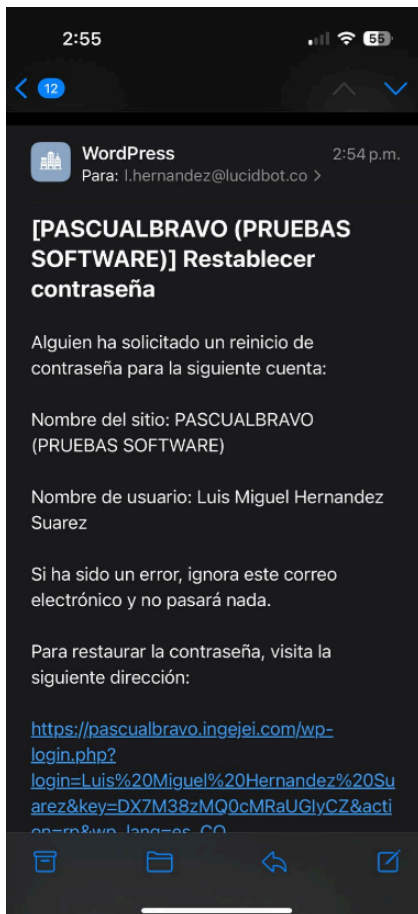
\$18.00

Total

\$18.00

Prueba fallida

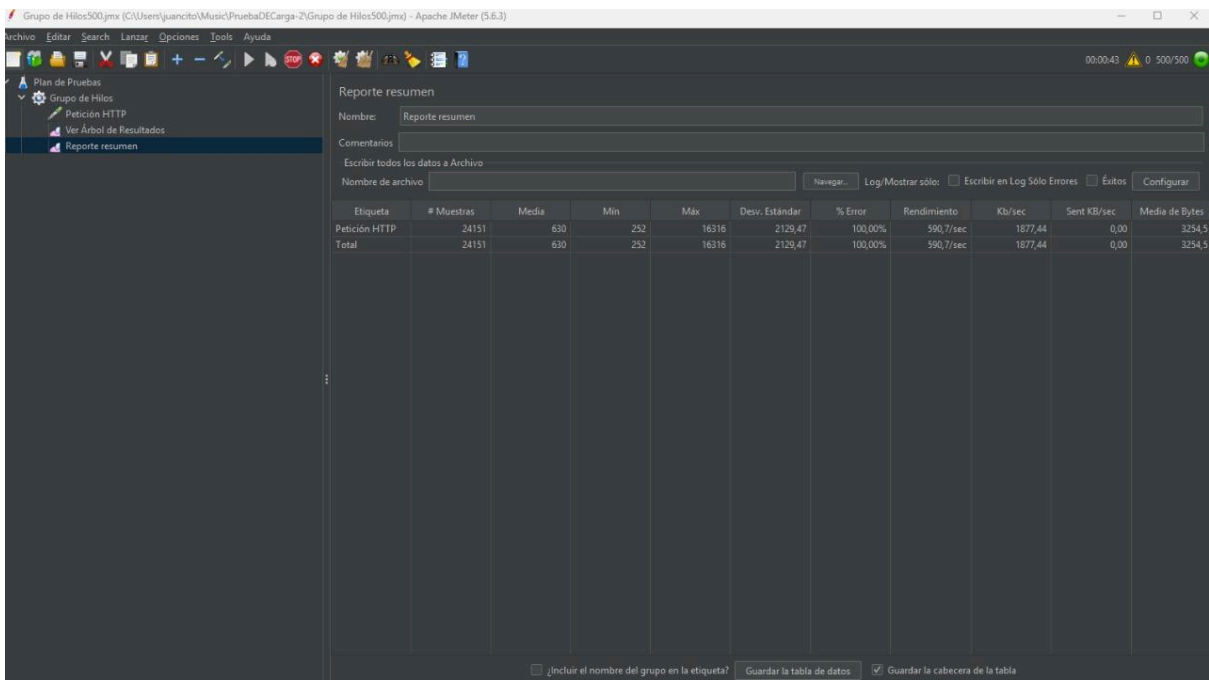
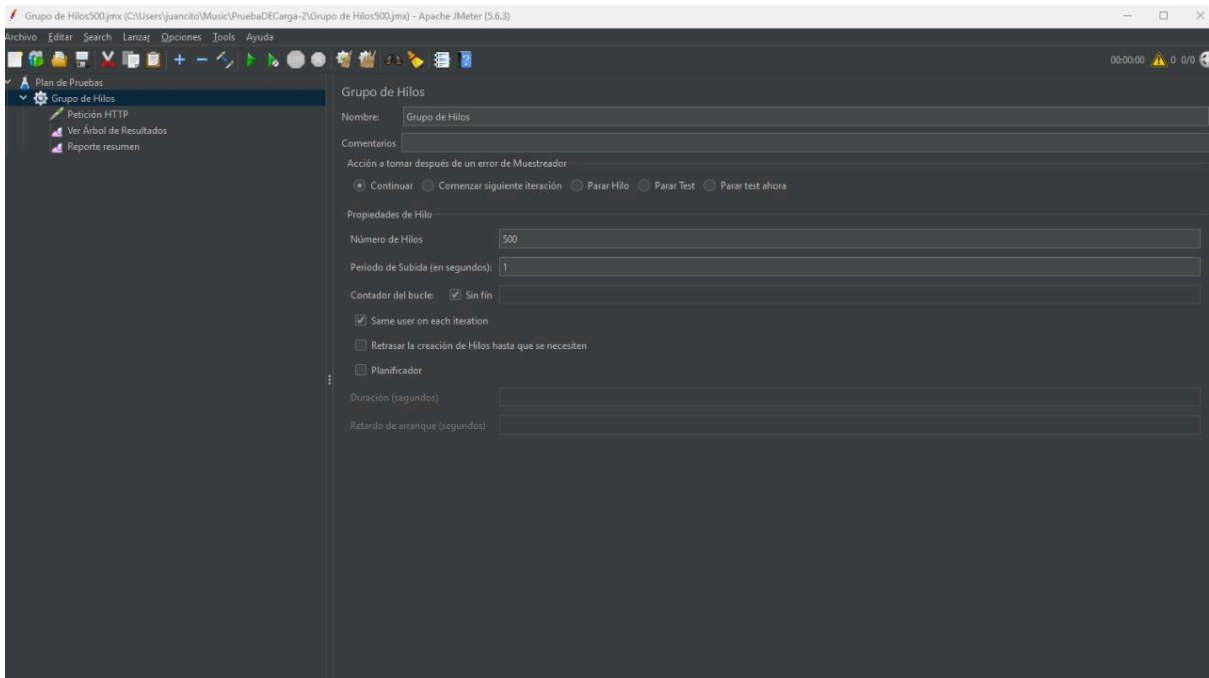
Quinta prueba realizada por Luis Miguel Hernandez (PF-05)

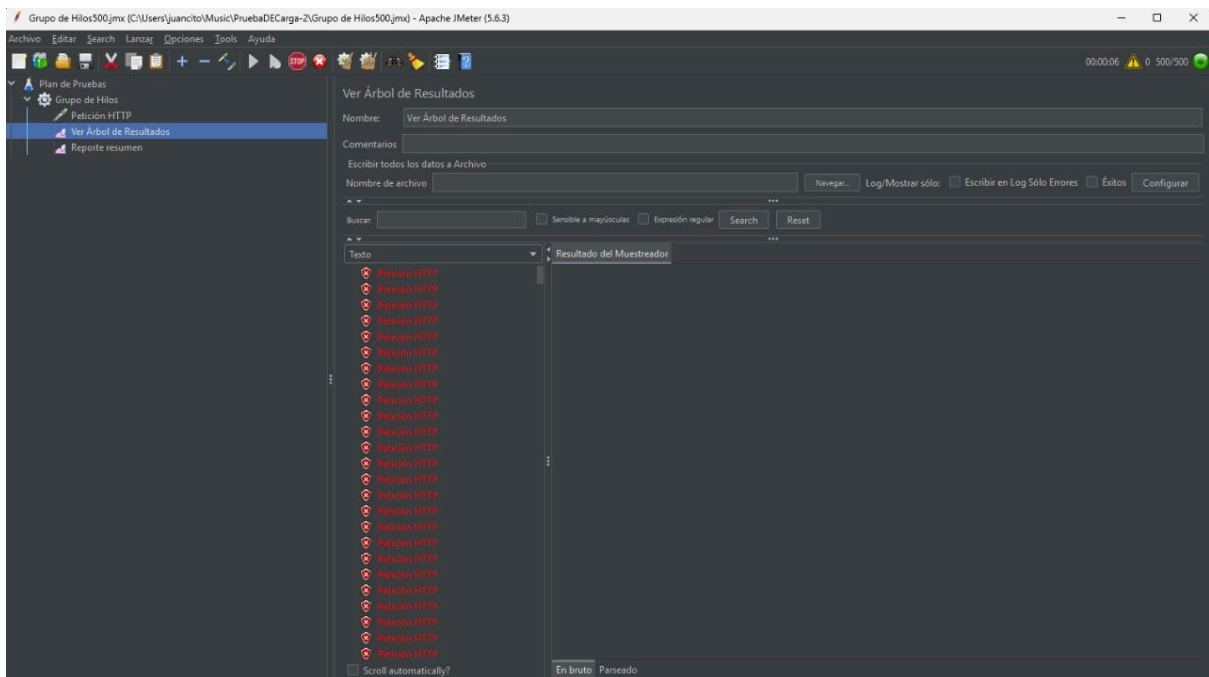


Prueba exitosa

Pruebas de Carga

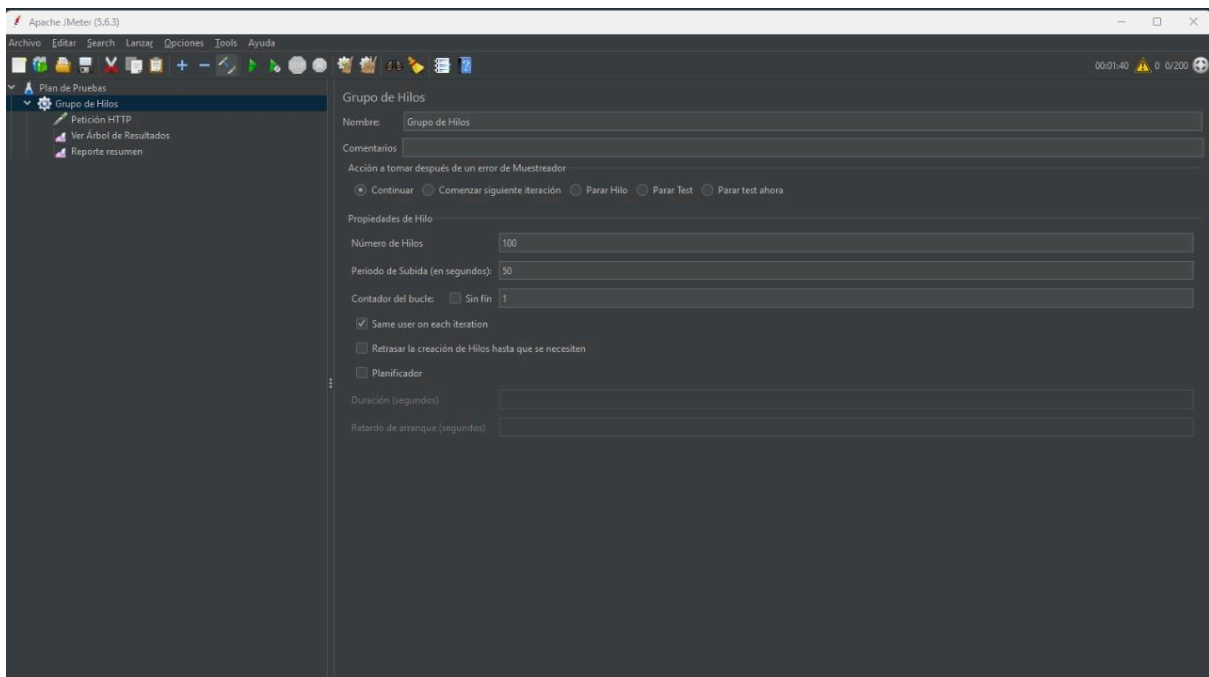
Primer prueba realizada por Juan Manuel Reina (PC-01)



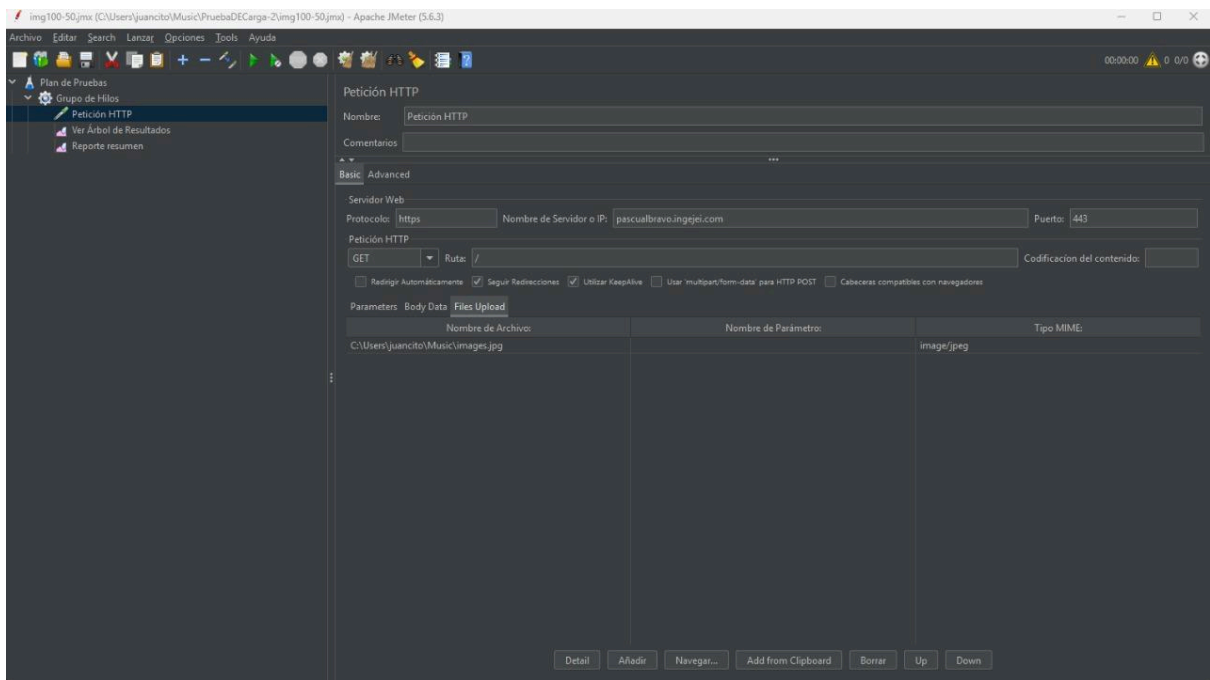
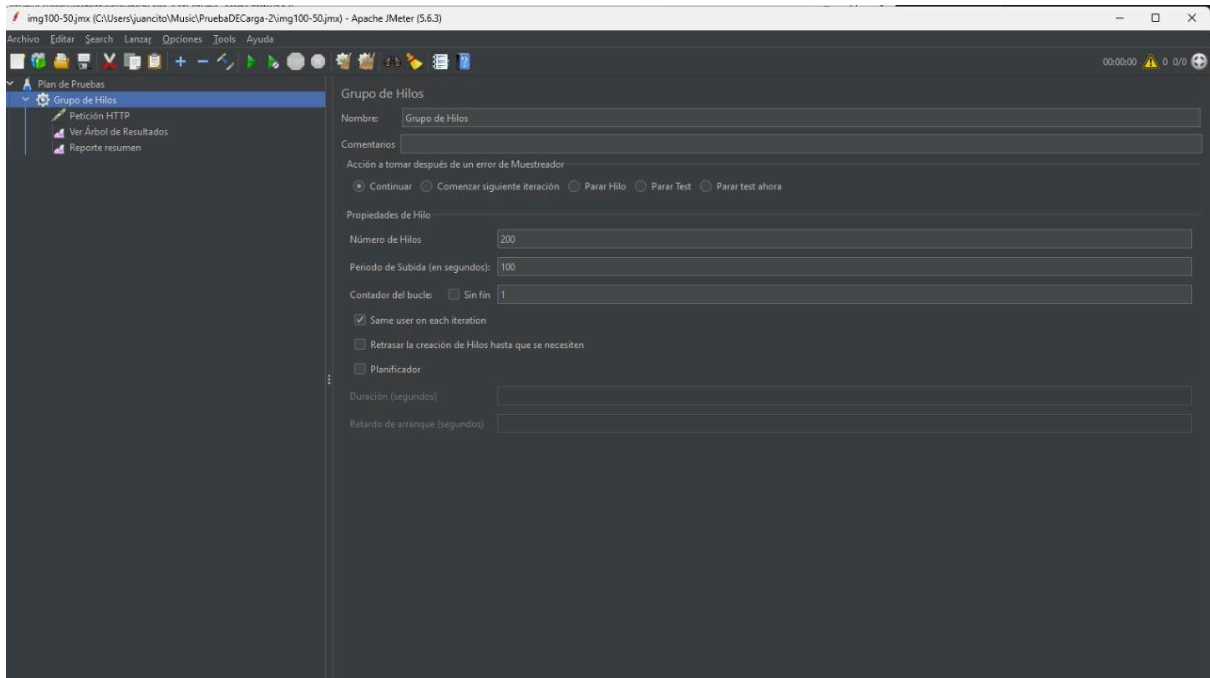


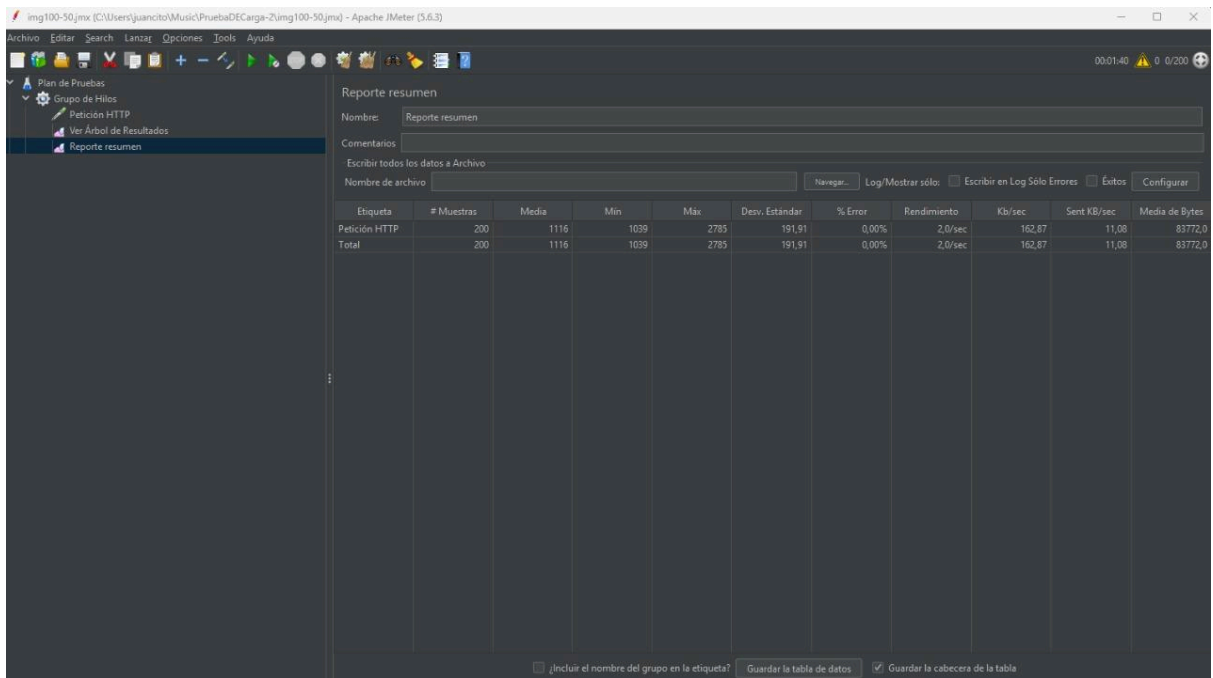
Prueba fallida

Segunda prueba realizada por Juan Manuel Reina (PC-02)



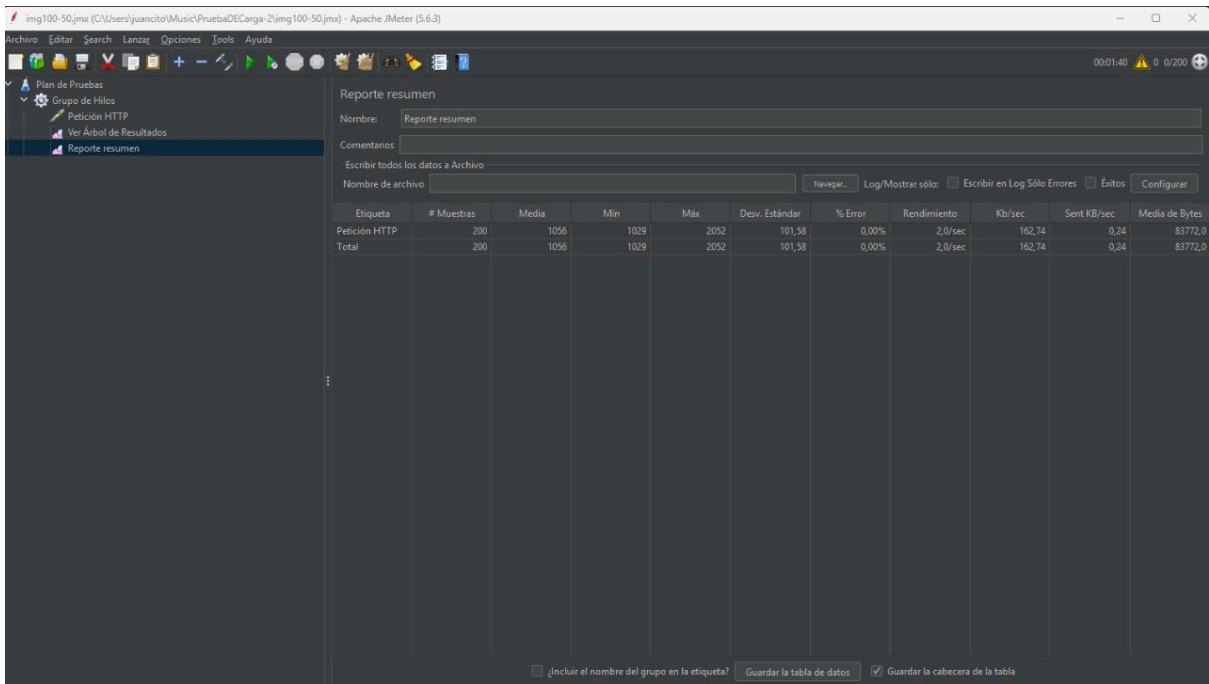
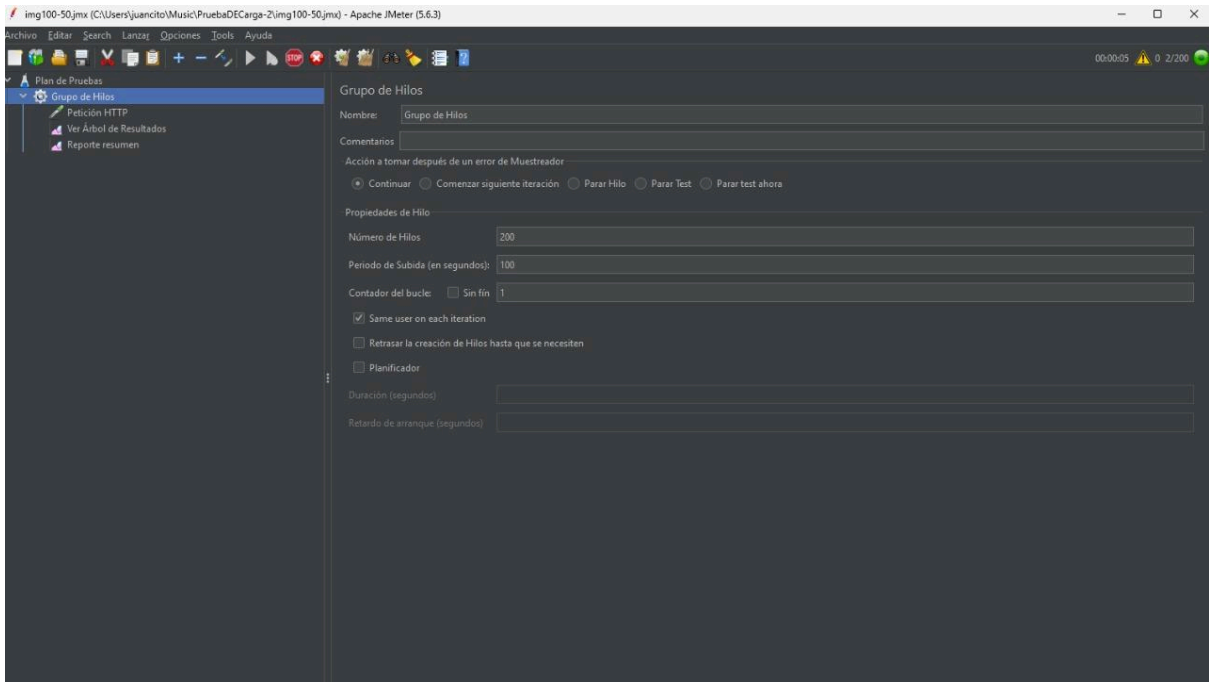
Tercera prueba realizada por Juan Manuel Reina (PC-03)

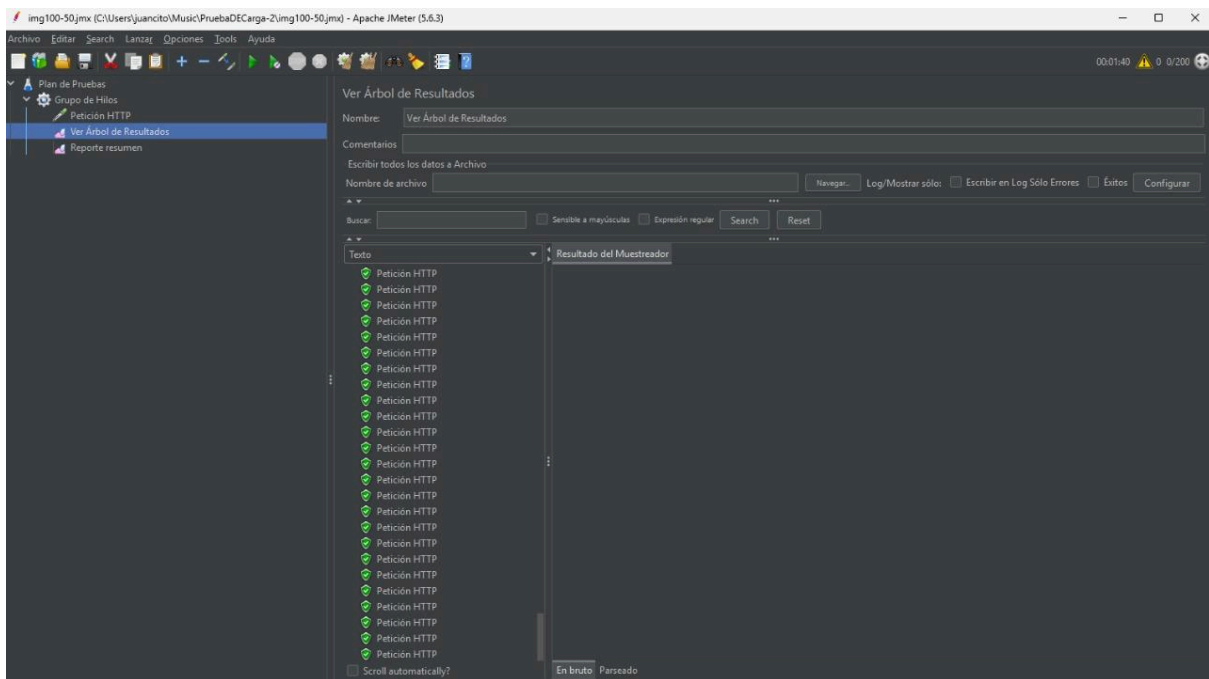




Prueba exitosa

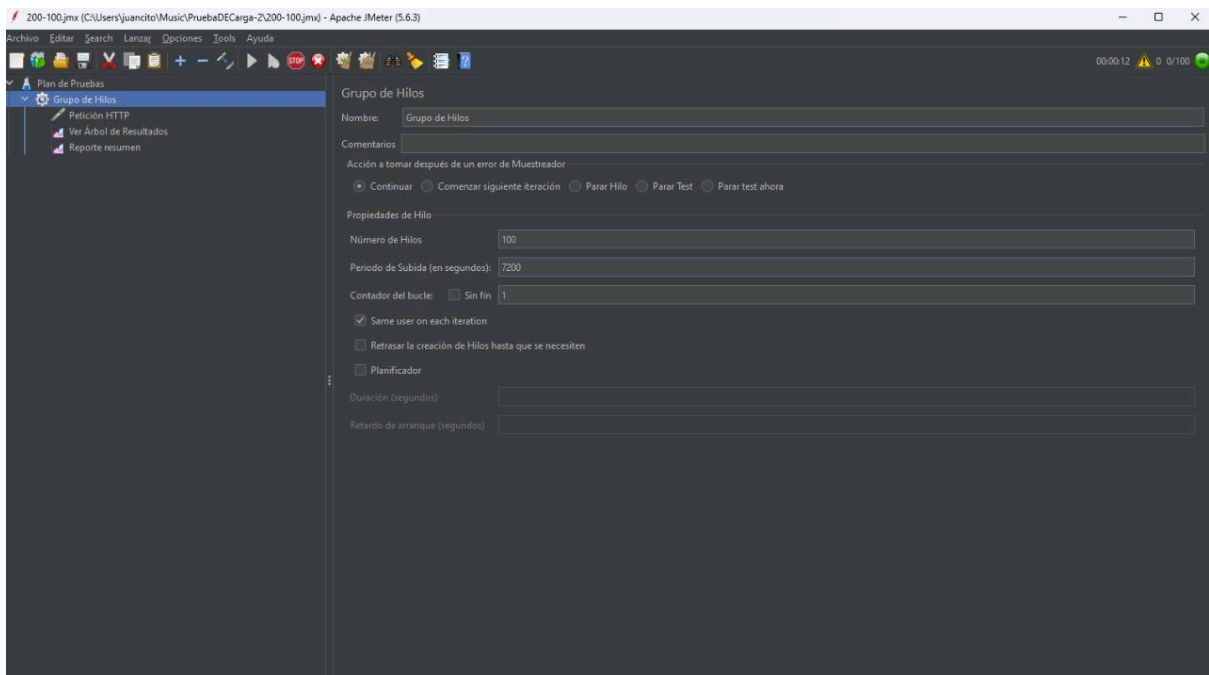
Cuarta prueba realizada por Juan Manuel Reina (PC-04)





Prueba exitosa

Quinta prueba realizada por Juan Manuel Reina (PC-05)



Pruebas de Seguridad

Primer prueba realizada por Juan David Benjumea (PC-01)

```
(root@kali)-[/home/kali]
# ./test_SQLInjection.sh
[*] Iniciando escaneo SQL Injection con sqlmap...

{1.9.3#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 22:27:12 /2025-06-04/

[22:27:12] [INFO] testing connection to the target URL
[22:27:16] [INFO] testing if the target URL content is stable
[22:27:18] [INFO] target URL content is stable
[22:27:18] [INFO] testing if POST parameter 'username' is dynamic
[22:27:21] [WARNING] POST parameter 'username' does not appear to be dynamic
[22:27:24] [WARNING] heuristic (basic) test shows that POST parameter 'username' might not be injectable
[22:27:26] [INFO] testing for SQL injection on POST parameter 'username'
```

Prueba exitosa

Segunda prueba realizada por Juan David Benjumea (PC-02)

```
(root@kali)-[/home/kali]
# hydra -L usuarios.txt -P password.txt pascualbravo.ingejei.com http-post-form "/my-account/:username=^USER^&password=^PASS^:Error" -V -t 4 -f

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-05 00:35:37
[DATA] max 4 tasks per 1 server, overall 4 tasks, 484 login tries (l:22/p:22), ~121 tries per task
[DATA] attacking http-post-form://pascualbravo.ingejei.com:80/my-account/:username=^USER^&password=^PASS^:Error
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "123456" - 1 of 484 [child 0] (0/0)
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "password" - 2 of 484 [child 1] (0/0)
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "qwerty" - 3 of 484 [child 2] (0/0)
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "abc123" - 4 of 484 [child 3] (0/0)
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "letmein" - 5 of 484 [child 1] (0/0)
[ATTEMPT] target pascualbravo.ingejei.com - login "juan.benjumea316@pascualbravo.edu.co" - pass "123456" - 6 of 484 [child 0] (0/0)
```

Prueba exitosa

Tercer prueba realizada por Juan David Benjumea (PC-03)

```
(root@kali)-[/home/kali]
# ./test_roles.sh
Probando login para Super Admin: JEISIM18@GMAIL.COM
Super Admin: Login exitoso. Acceso al panel de administración confirmado.

Probando login para Usuario Normal: juan.benjumea316@pascualbravo.edu.co
Usuario Normal: Login fallido o acceso al panel denegado.
```

Prueba exitosa

Cuarta prueba realizada por Juan David Benjumea (PC-04)

```
(root@kali)-[/home/kali]
# ./test_headers.sh
Revisando encabezados HTTP de seguridad en: https://pascualbravo.ingejei.com
content-security-policy: upgrade-insecure-requests
```

Prueba exitosa

Quinta prueba realizada por Juan David Benjumea (PC-05)

```
(root@kali)-[/home/kali]
# ./test_csrf.sh
Iniciando sesión ...
Accediendo al formulario de edición ...
Token CSRF encontrado: save-account-details-nonce = 2ff8d1c12d
Enviando formulario CON token ...
Enviando formulario SIN token ...

Con token: No se aplicaron los cambios.
Sin token: Protección CSRF activa. Cambios rechazados.
```

Prueba exitosa

Conclusiones:

- Al hacer las pruebas del registro, búsqueda y pago, noté que el sitio en general responde bien y es fácil de usar. Las funciones básicas funcionan sin errores, lo cual es clave. Hubo momentos donde el envío de correos no fue tan consistente, así que es algo que valdría la pena revisar mejor.

- Hacer este trabajo fue mucho más que solo aplicar pruebas o usar herramientas. Me hizo pensar en todo lo que hay detrás de una página web y en lo fácil que es pasar por alto detalles importantes. Aprendí a ver la aplicación desde distintos puntos de vista: si funciona bien, si resiste cuando muchas personas la usan al mismo tiempo y si realmente es segura. Hubo momentos en los que me equivoqué, en los que no entendía del todo lo que pasaba, pero eso fue lo que más me ayudó a aprender. Al final entendí que, aunque algo parezca estar funcionando bien, siempre hay algo que se puede mejorar.

- Revisando los encabezados vemos que el sitio solo está aplicando una política mínima, que fuerza a los navegadores a convertir cualquier recurso HTTP a HTTPS, pero no protege contra inyecciones ni clickjacking de forma robusta.

[Content-Security-Policy: upgrade-insecure-requests](#)

Eso solo mitiga recursos inseguros (carga por HTTP), pero no bloquea scripts maliciosos, inline JS o iframes peligrosos.

Faltan encabezados clave:

- X-Frame-Options: Previene clickjacking
- Strict-Transport-Security: Evita ataques de downgrade a HTTP
- X-Content-Type-Options: Previene ataques MIME sniffing